



Konrad Sagała

Ochrona DevOps w środowisku
multicloud narzędziami Microsoft



**Expert
Summit 2025**

All about Microsoft® technologies

ONLINE

Sala B

Godz. 16:00



techevents



TROCHĘ O SOBIE

- Cloud Security Architect – Azure/M365
- Microsoft Certified Trainer since 2007
- Microsoft MVP since 2007 – M365 & Security
- Twitter - [@sagus](https://twitter.com/sagus)
- LinkedIn - [@konradsagala](https://www.linkedin.com/in/konradsagala)
- Github - <https://github.com/ksagala>
- Blog – <https://pepugmaster.blogspot.com>
- Hobby – Podróże, Śpiew, Taniec



Agenda

- Understanding DevSecOps and the Need for Security in DevOps
- Importance of Security in the DevOps Lifecycle
- Overview of Defender for Cloud and Its Security Capabilities
- Protecting DevOps Tools with Defender for Cloud
- Best Practices for DevSecOps with Defender for Cloud

Understanding DevSecOps and the Need for Security in DevOps

DevSecOps and Its Core Principles



What is DevOps

The **DevOps model** is a modern approach that integrates **development (Dev)** and **operations (Ops)** teams to streamline the software development lifecycle. It emphasizes **collaboration, automation, and continuous improvement** to deliver high-quality software faster and more reliably.

Integration of Security

DevSecOps embeds security practices into every stage of the DevOps lifecycle for proactive risk management.

Key Differences Between DevOps and DevSecOps

Focus of DevOps

DevOps emphasizes collaboration between development and operations teams to improve software delivery speed and reliability.

Introduction of Security in DevSecOps

DevSecOps integrates security practices from the start, making security a shared responsibility across all teams.

Security Throughout Process

Security is embedded throughout the software lifecycle in DevSecOps, ensuring continuous protection and compliance.

Risks and Challenges in Unsecured DevOps Environments

Vulnerability to Misconfigurations

DevOps pipelines lacking proper security are prone to misconfigurations that expose the environment to threats.

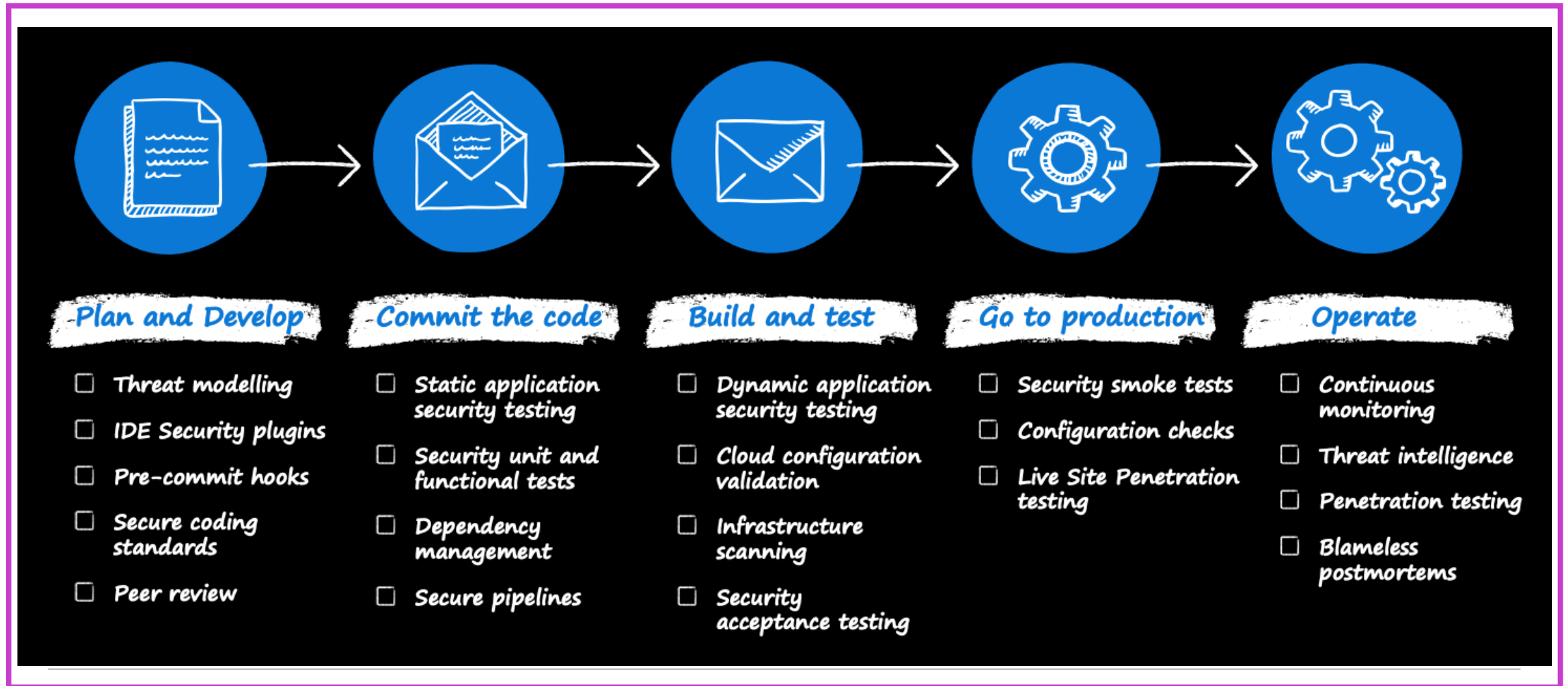
Supply Chain Attacks

Unsecured DevOps environments face risks from supply chain attacks compromising software integrity.

Unauthorized Access Risks

Lack of integrated security leads to unauthorized access, increasing chances of data breaches and compliance failures.

High level DevSecOps process



<https://learn.microsoft.com/en-us/azure/well-architected/security/secure-development-lifecycle>

Challenges and How to Overcome Them

Adopting DevSecOps isn't without hurdles.

Common challenges include:

- **Resistance to Change:** Developers may resist additional security steps. Address this through training and by demonstrating the value of early vulnerability detection.
- **Tool Overload:** Too many tools can overwhelm teams. Prioritize tools that integrate seamlessly with existing workflows.
- **Skill Gaps:** Not all developers are security experts. Invest in ongoing training and pair developers with security champions.

Importance of Security in the DevOps Lifecycle

Threats Targeting DevOps Pipelines and Toolchains

Code Injection Threats

Code injection attacks introduce malicious code into DevOps pipelines, risking data integrity and system stability.

Compromised Credentials

Stolen or weak credentials enable unauthorized access, threatening pipeline security and operations.

Vulnerable Third-Party Components

Using vulnerable third-party components exposes pipelines to security risks and potential exploits.

Benefits of Integrating Security Throughout the Development Process

Early Vulnerability Reduction

Embedding security early in development minimizes vulnerabilities before they become risks.

Faster Remediation

Early security enables quicker identification and resolution of security issues.

Compliance Assurance

Integrating security ensures adherence to regulatory and industry compliance standards.

Resilient Software Delivery

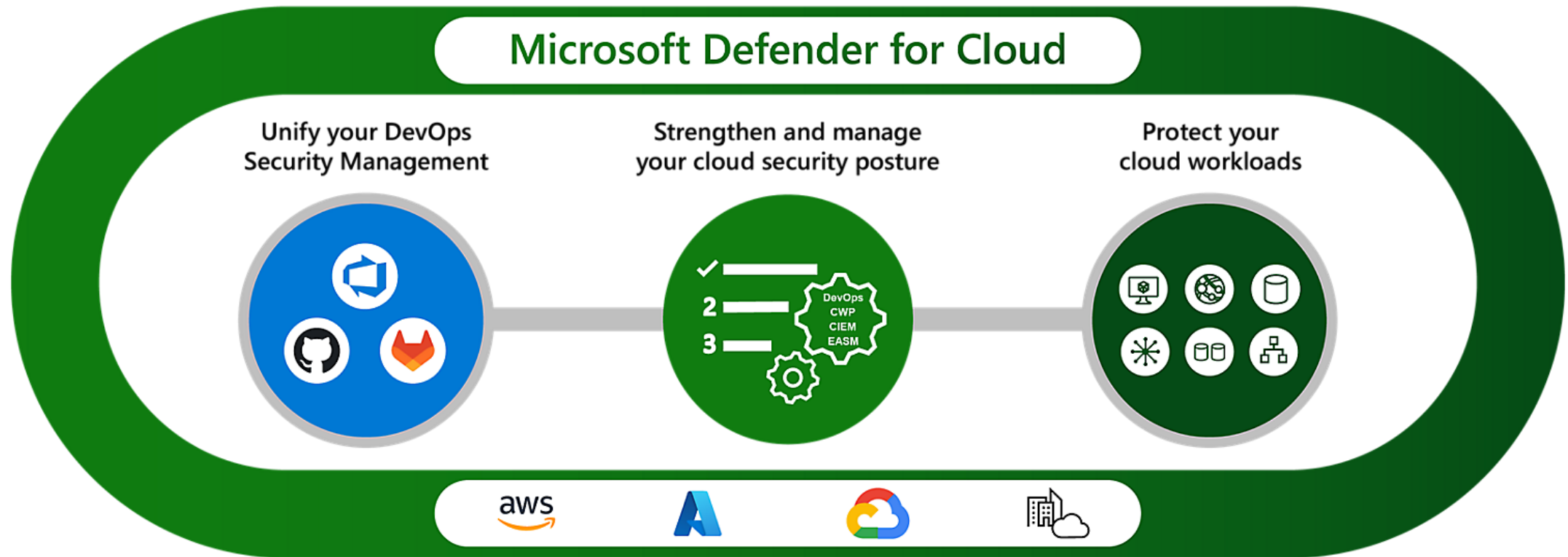
Security throughout development leads to robust and trustworthy software products.

MCSB—controls for DevOps security

-  DS-1: Conduct threat modeling
-  DS-2: Ensure software supply chain security
-  DS-3: Secure DevOps infrastructure
-  DS-4: Integrate static application security testing into DevOps pipeline
-  DS-5: Integrate dynamic application security testing into DevOps pipeline
-  DS-6: Enforce security of workload throughout DevOps life cycle
-  DS-7: Enable logging and monitoring in DevOps

Defender for Cloud and Its Security Capabilities

Microsoft Defender for Cloud



Key Features and Architecture

Continuous Security Assessment

Provides ongoing evaluation of security posture to identify risks and vulnerabilities in real time.

Advanced Threat Protection

Detects and responds to sophisticated cyber threats using intelligent analytics and machine learning.

Vulnerability Management

Identifies and manages potential vulnerabilities to reduce the attack surface effectively.

Compliance Monitoring

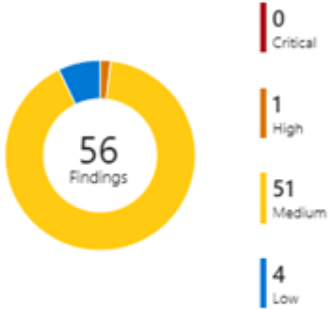
Ensures continuous adherence to regulatory and organizational compliance standards.

Key Features and Architecture

[+ Add environment](#) [Refresh](#) [DevOps workbook](#) [→ Getting Started](#) [Manage resources](#) [Guides & Feedback](#)

Security Overview

DevOps security findings ⓘ



DevOps security results ⓘ



 25
Infrastructure as Code findings



DevOps advanced security resources coverage

Azure DevOps	0/11
Learn more >	
GitHub	1/2
Learn more >	
GitLab (Not applicable) ⓘ	-/8

Search

Subscription == SubMCT

Resource type : All

Finding type : All

Severity : All

Resource hierarchy view

Name	DevOps environment	Advanced security status	Pull request status	Findings
ilab	Azure DevOps	Off	Off	55
Mend Lab	Azure DevOps	Off	Off	30
WebGoat	Azure DevOps	Off	Off	30
alzbicep	Azure DevOps	Off	Off	24
alztft	Azure DevOps	Off	Off	1
artifactsDemo	Azure DevOps	Off	Off	0
Sentinel Content	Azure DevOps	Off	Off	0
MDC Demo project	Azure DevOps	Off	Off	0

Integration with DevOps Toolchains

Seamless Tool Integration

Integrates smoothly with popular DevOps tools such as GitHub and Azure DevOps to streamline workflows.

Automated Security Scans

Enables automated security scanning within CI/CD pipelines to detect vulnerabilities early.

Policy Enforcement and Incident Detection

Supports policy enforcement and incident detection to maintain security compliance during deployments.

<https://www.microsoft.com/en-us/security/blog/2023/04/06/devops-threat-matrix/>

Understand your DevOps security

Page section	Description
Security Overview DevOps security findings ⓘ  2.6K High 3.1K Medium 736 Low DevOps security results ⓘ 2347 Code findings 1474 Infrastructure as Code findings 976 Secret findings 1644 Dependency findings	Total number of DevOps security scan findings (code, secrets, dependency, infrastructure-as-code) grouped by severity level and by finding type.
DevOps environment posture management recommendations ⓘ 0 High severity recommendations, on 0 resources Recommendations results. Open> Learn more >	Provides visibility into the number of DevOps environment posture management recommendations highlighting high severity findings and number of affected resources.
DevOps advanced security resources coverage ⓘ Azure DevOps 4/133 Learn more > GitHub 59/152 Learn more > GitLab (Not applicable) ⓘ -/43	Provides visibility into the number of DevOps resources with advanced security capabilities out of the total number of resources onboarded by environment.

Protecting DevOps Tools with Defender for Cloud

Securing CI/CD Pipelines (GitHub, Azure DevOps)

Pipeline Security Integration

Defender for Cloud integrates security checks directly into CI/CD pipelines to ensure continuous protection.

Early Vulnerability Prevention

Security checks during build and deployment prevent vulnerabilities from entering production environments.

Securing CI/CD Pipelines (GitHub, Azure DevOps)

Extensions

SecurityBrowse marketplace

InstalledRequestedShared

Filter by keywordsState

Extension	State	Description
 Delivery Plans by Microsoft	Active	Manage your portfolio of work with a calendar based view across teams and projects.
 Microsoft Security DevOps by Microsoft	Active	Build tasks for performing security analysis.
 SARIF SAST Scans Tab by Microsoft DevLabs	Active	Adds a 'Scans' tab to each Build Result and Work Item for viewing associated SARIF SAST logs.

<https://learn.microsoft.com/en-us/azure/defender-for-cloud/azure-devops-extension>

Automated Vulnerability Scanning and Policy Enforcement

Automated Vulnerability Scanning

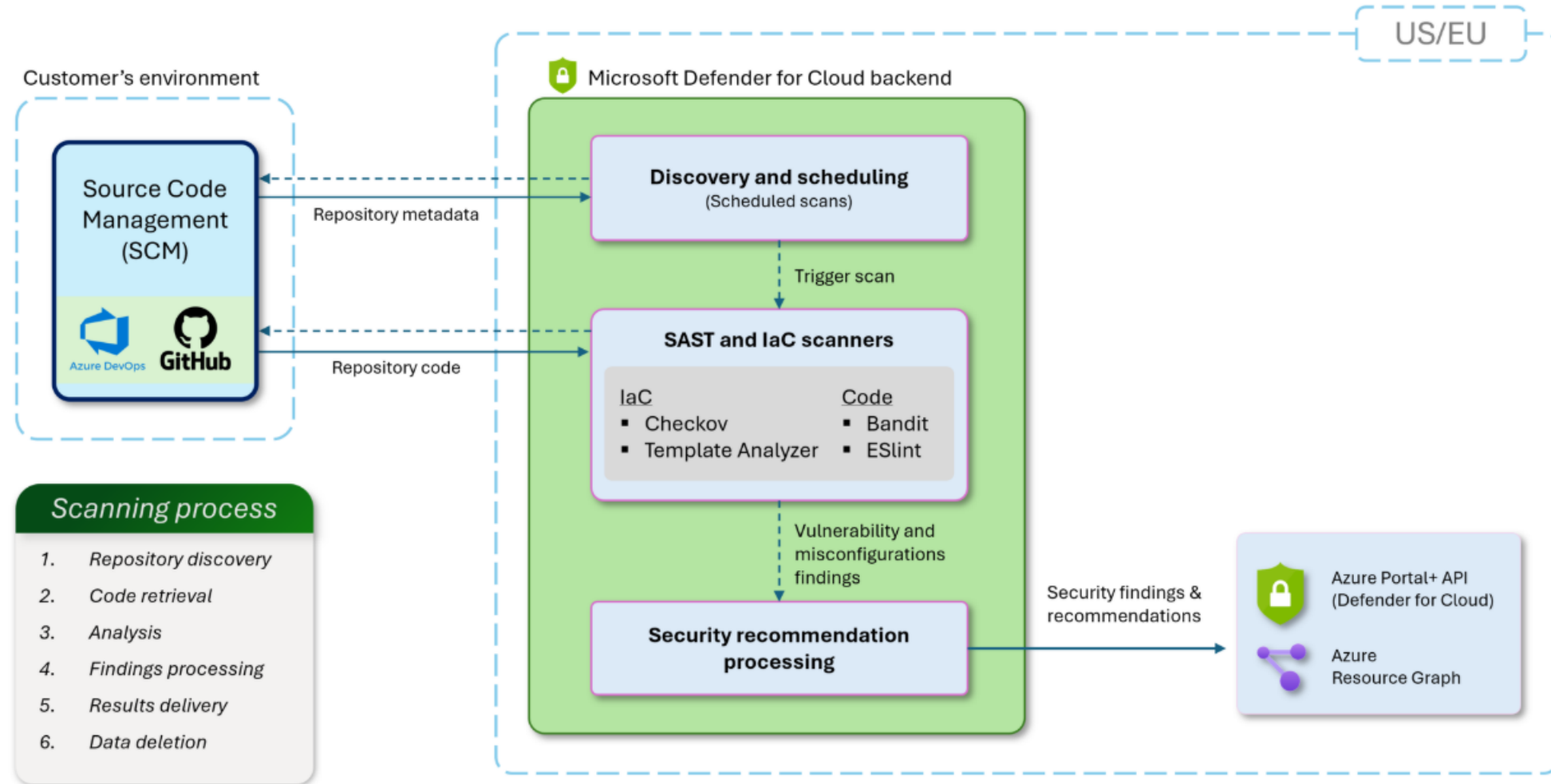
Scans code and dependencies automatically to identify security vulnerabilities promptly and efficiently.

Policy Enforcement

Enforces security policies consistently to ensure compliance and reduce organizational risk.

Agentless code scanning (preview)

How agentless code scanning works



Supported regions: Australia East, Canada Central, Central US, East Asia, East US, North Europe, Sweden Central, UK South, West Europe

Other preview features

- Integration Defender for Cloud CLI with CI/CD pipelines –
<https://learn.microsoft.com/en-us/azure/defender-for-cloud/cli-cicd-integration>
- Integration with Mend.io SCA –
<https://learn.microsoft.com/en-us/azure/defender-for-cloud/integration-mend-io>
- Integration with Endor Labs SCA -
<https://learn.microsoft.com/en-us/azure/defender-for-cloud/integration-endor-labs>

Monitoring and Responding to Security Incidents in DevOps Environments

Continuous Security Monitoring

Defender for Cloud continuously monitors DevOps environments for suspicious activities to ensure security.

Alerting and Rapid Response

Timely alerts enable quick responses to security incidents within DevOps toolchains, minimizing risks.

Best Practices for DevSecOps with Defender for Cloud

Implementing Continuous Security Assessment

Regular Security Assessments

Conducting regular security assessments ensures early detection of potential vulnerabilities in the development lifecycle.

Automated Vulnerability Detection

Automation enables continuous vulnerability scanning, reducing manual effort and increasing assessment frequency.

Integrating Security in Development

Embedding security assessment throughout development maintains protection and reduces risk of breaches.



Role-Based Access Control and Secrets Management

Precise Access Rights

Role-based access control ensures users have only necessary permissions, reducing risks of unauthorized access.

Secrets Management

Securely managing secrets like passwords and keys prevents data leaks and strengthens security in DevOps.

Ongoing Training and Collaboration Between Development, Security, and Operations Teams

Shared Responsibility Culture

Encouraging a culture of shared responsibility enhances security by involving all teams in proactive measures.

Continuous Training

Regular training sessions improve security awareness and keep teams updated on best practices.

Effective Communication

Open communication channels between development, security, and operations improve coordination and response times.



Conclusion

Security Integration

Defender for Cloud embeds security directly into DevOps workflows to ensure continuous protection.

Risk Mitigation

It helps mitigate risks by identifying vulnerabilities early in the software delivery process.

Compliance and Efficiency

Enables compliant and efficient software delivery in modern DevSecOps environments.



Dziękuję za uwagę

